Channel-Aware Backdoor Attacks

Against Federated Infostealer Malware Classification

Using Dynamic API-Call and Network Representations

Mochamad Asryl Aziz · Moh. Jabir Mubarok · Eka Fitria

IWBIS

Federated learning helps, and opens a door

- Infostealers take credentials, browser data and session cookies, so classifying the family feeds triage and incident response.
- Dynamic analysis carries the signal: API calls for host execution, network artifacts for communication. Both encode as CNN images.
- Federated learning trains one classifier without moving raw data, but the server sees only client updates, never the local data.

The server cannot inspect local training data. That is the opening a malicious client needs.

One image, three channels

R	API-call tile
G	network tile
B	edge map of (R+G)/2, derived from the other two

Most FL backdoor work looks past the channels

Prior FL backdoor work	targets general image tasks or model-level poisoning, not channel-specific behavior in malware representations
Malware backdoor work	explanation-guided and family-selective triggers on static features of a centralized classifier
This work	attacks a federated model through the channels of a dynamic-behavior image, a setting that remains underexplored

An RGB-stack puts API-call, network and fused information in separate channels, so a trigger in one channel need not behave like a trigger in another.

We treat the channels as the attack surface

1 Build dynamic API-call and network representations from Cuckoo Sandbox reports for five Windows infostealer families.

2 Select the representation and backbone: RGB-stack for its explicit channel separation, then the strongest backbone within it.

3 Evaluate red/API, green/network, blue/fusion and full-RGB triggers, with trigger controls and a Multi-Krum defense analysis.

The finding

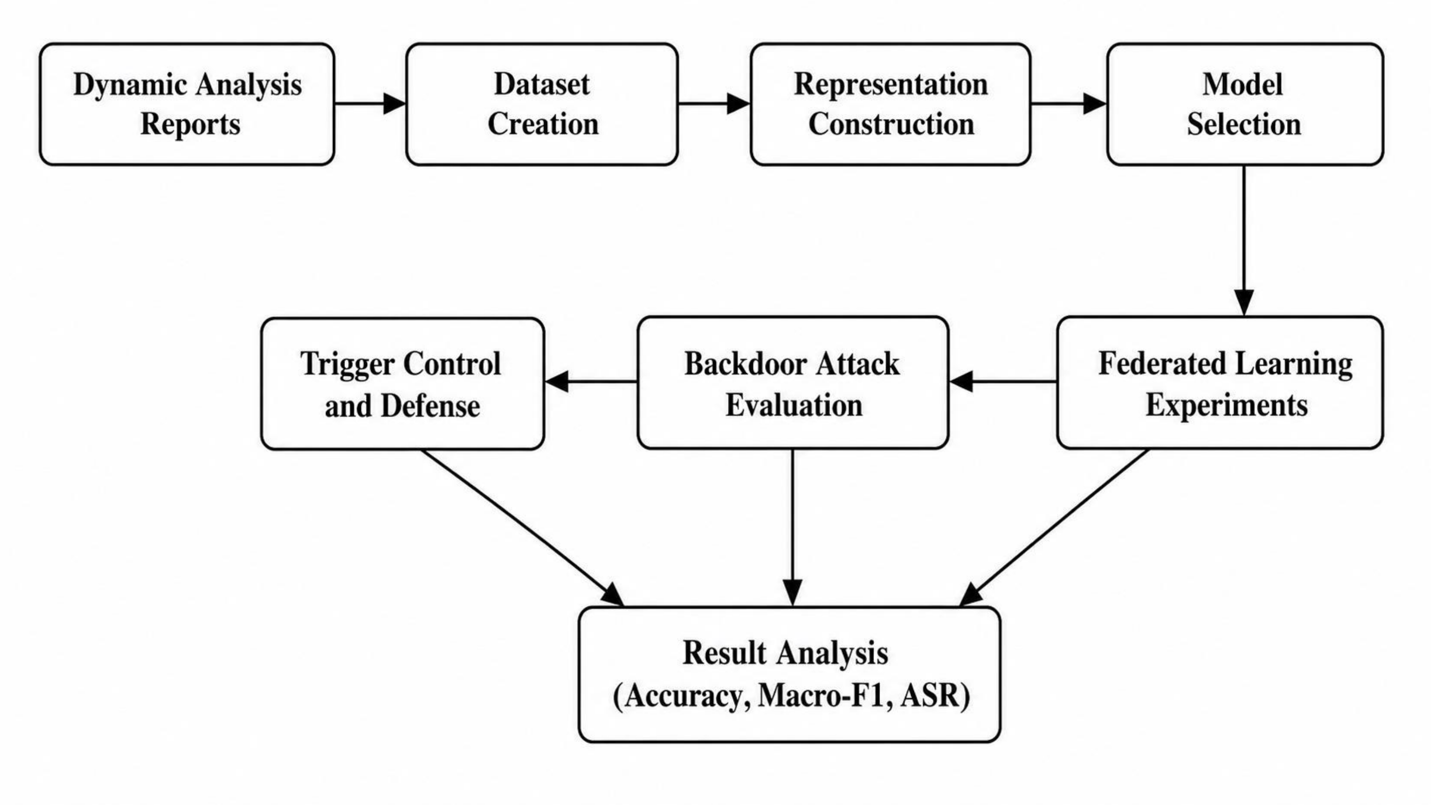
15/15

attack success on every seed, for a trigger in the fusion channel alone and for one spanning all three

Attack success rate: AgentTesla test images predicted FormBook.

Clean performance stays close to the clean federated baseline. Channel-aware backdoors are a serious threat to federated malware classifiers in this controlled IID setting, and motivate representation-aware defenses.

The whole study on one page

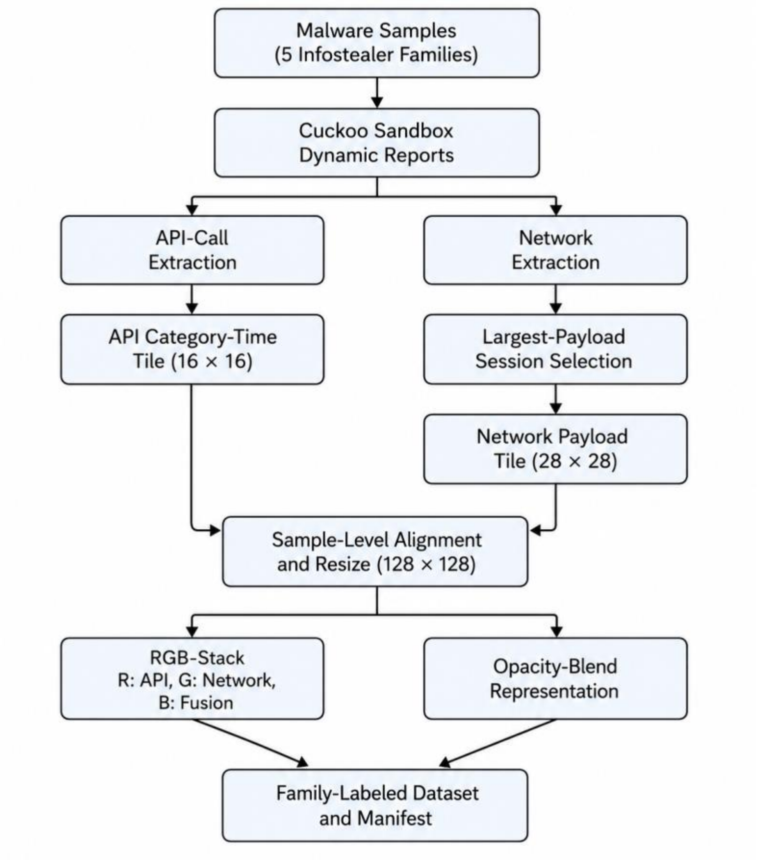


The next six slides follow these blocks in order

- **Dataset creation**
  five families, stratified split
- **Representation**
  RGB-stack, and what blue is
- **Model selection**
  backbone within RGB-stack
- **Federated learning**
  five clients, one malicious
- **Attack and control**
  channel-aware trigger
- **Defense**
  Multi-Krum and three baselines

Everything is dynamic analysis: API-call traces and network artifacts from Cuckoo Sandbox, with no static file features.

Five families, 100 samples each, 15 in test



Family	Train	Val	Test	Total
AgentTesla	70	15	15	100
FormBook	70	15	15	100
SalatStealer	70	15	15	100
StealC	70	15	15	100
Vidar	70	15	15	100
Total	**350**	**75**	**75**	**500**

Only the largest-payload session per sample is kept, to limit sample-level leakage. The split is stratified by family and re-drawn for every seed, so the seeds do not share a test set.

AgentTesla is the attack's source family, so every attack success rate in this talk is a count out of those 15 test images.

Blue is derived from red and green, and is nearly empty

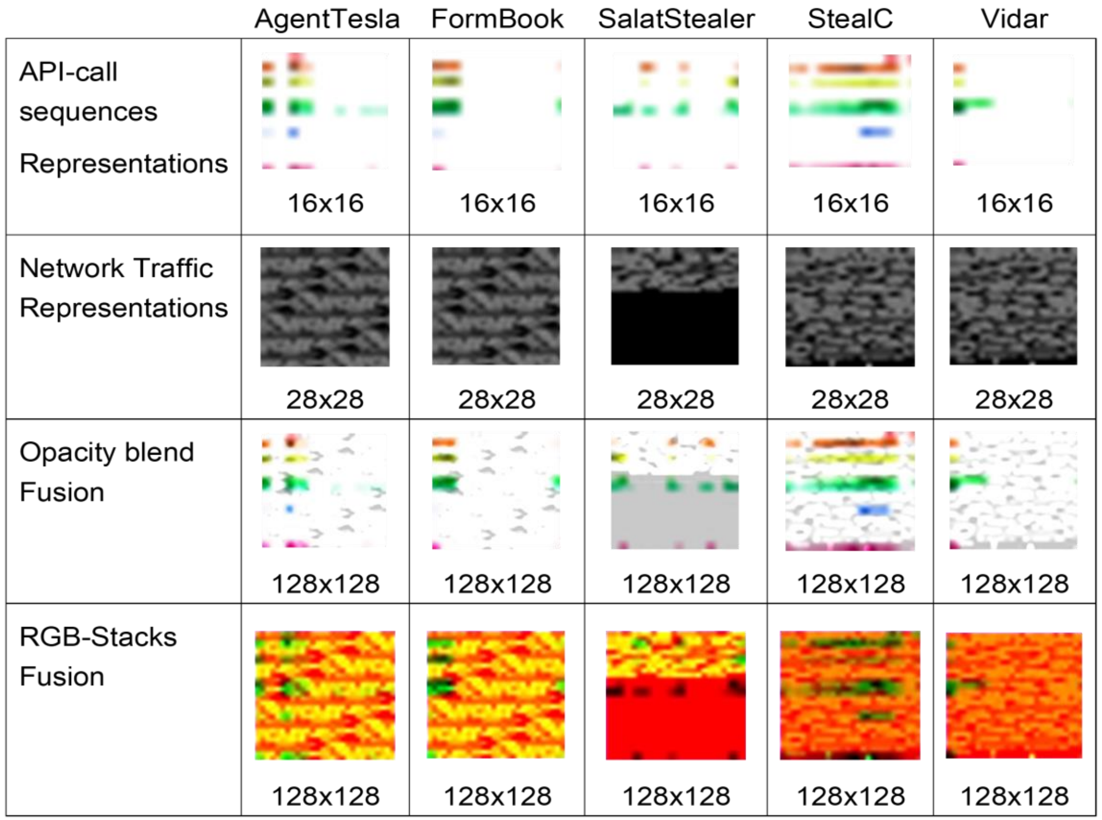
R API-call tile, 16 x 16, upscaled

G network tile, 28 x 28, upscaled

B edge map of the average of R and G

B = FindEdges((R + G) / 2)

A 3 x 3 edge convolution, so blue is a deterministic function of the other two and adds no independent information. It is also the emptiest channel: 62.8% of its pixels are exactly zero across the 500 images, 54.5% in AgentTesla.



Processed representations, one column per family. Opacity blend mixes both sources into every channel; RGB-stack is used because only it separates the sources by channel.

RGB-stack for channel separation, ResNet18 within it

Representation	Backbone	Acc.	Macro-F1
Opacity blend	SmallCNN	0.5333	0.5298
Opacity blend	MobileNetV2	0.6933	0.6903
Opacity blend	ResNet18	0.7733	0.7730
RGB-stack	SmallCNN	0.5200	0.5144
RGB-stack	MobileNetV2	0.7200	0.7200
RGB-stack	**ResNet18**	**0.7867**	**0.7884**

SmallCNN, for reference

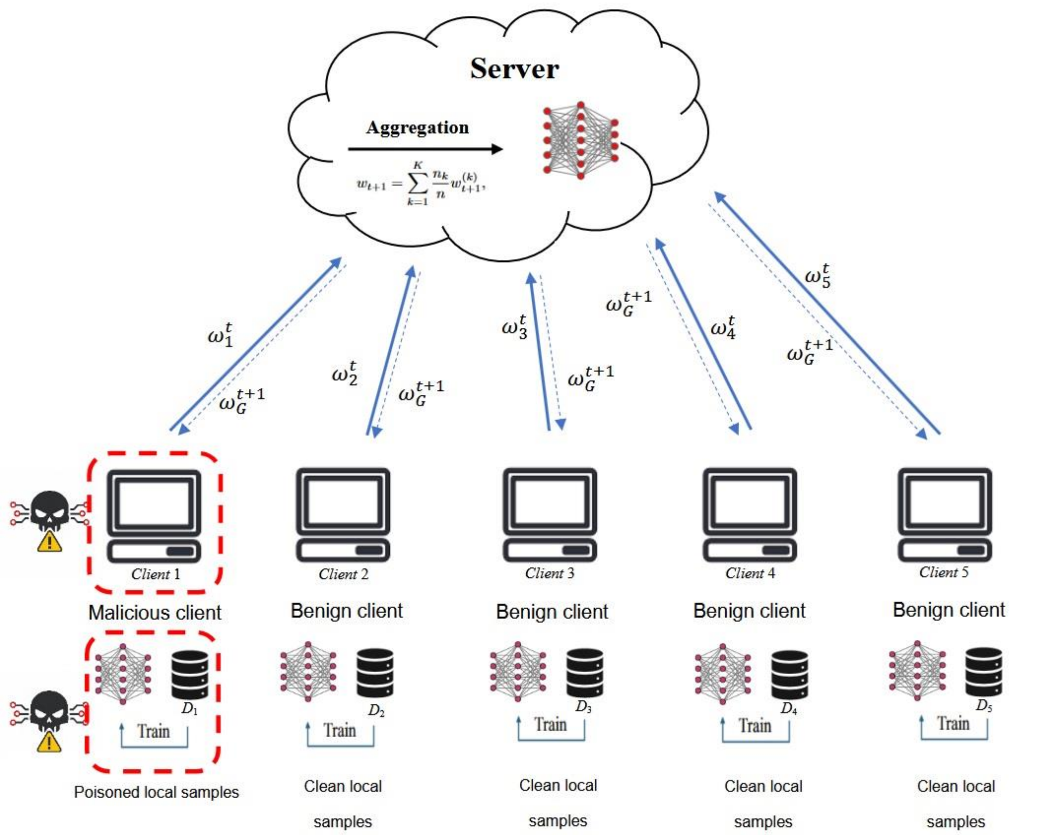
3 blocks 32, 64 and 128 channels

Conv 3 x 3 batch norm, ReLU, max-pool twice

From scratch as are MobileNetV2 and ResNet18

The two representations were generated from different split files, so this table is not a paired comparison. RGB-stack is chosen because channel separation is required here; macro-F1 selects only the backbone within it. Seed 42, ResNet18 trained from scratch with AdamW.

Five clients, one of them malicious



FedAvg

the server averages client updates by sample count, and never sees raw data

70 images

on every client, 14 per family, so the partition is balanced and IID

50 x 2

communication rounds by local epochs; the final-round global model is reported

Client 0

is malicious in every round, and submits like any other client

The malicious client's capability is pure data poisoning: no update scaling and no model replacement, so it is a weaker attacker than most federated backdoor work assumes.

The attacker is weak by design: two images per round

2 images

poisoned per round, resampled each round

12 x 12

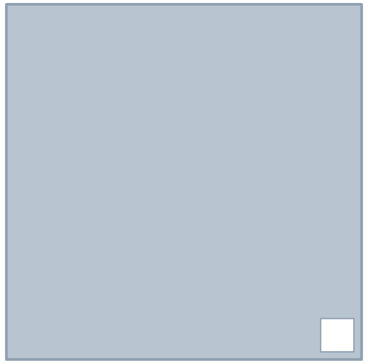
white square, written after normalization

4 triggers

red/API, green/network, blue/fusion, all three at once

15 targets

the AgentTesla test images the attack tries to flip



128 x 128, trigger to scale

AgentTesla is relabelled as FormBook. Both are infostealers, so the pair is a plausible same-category target.

Attack success rate is the share of the 15 triggered AgentTesla test images that the model calls FormBook. Because the trigger is confined to one channel at a time, the same attack can be run four ways on the same images.

The configured poison rate is 20% of the attacker's 14 AgentTesla images; the code truncates, so two images are poisoned each round, an effective 14.3%. That is 2 of the 350 global training images.

Four defenses screened, and one deviation disclosed

Multi-Krum	scores updates by distance to the others and averages the $\lvert S \rvert = 2$ lowest of five, with $f = 1$
Three baselines	L2-norm clipping, coordinate-wise median and trimmed mean, screened alongside it
Trigger control	the same trigger applied at test time to a clean model that never saw poisoned data

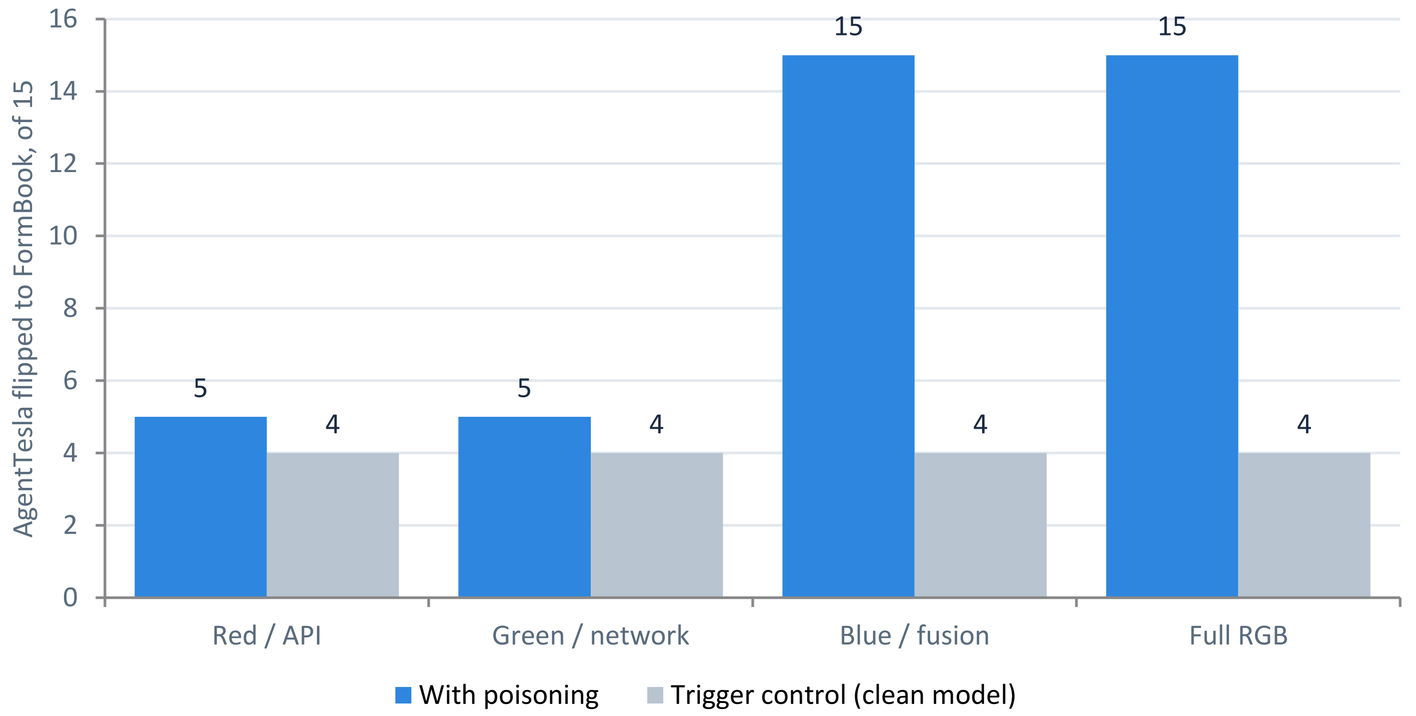
Disclosed deviation

The seed-42 clean baseline and its trigger controls come from a 30-round, one-local-epoch run, not the common 50 x 2 budget.

No attack success result is affected: every backdoor and defense run uses the common budget.

Screening every defense on every seed would multiply the budget for candidates that may not survive, and all runs share one GPU, so the screening narrows the field on a single seed first.

The channel decides whether the backdoor works



Fisher exact, pooled

Blue vs its control

$p = 3.5e\text{-}19$

Full RGB vs its control

$p = 2.6e\text{-}18$

Blue vs red and green

$p = 4.0e\text{-}08$

Red, green vs their controls

$p = 1$

Red and green are not distinguishable from a clean model at all.

Blue alone matches all three channels at once, and blue is a deterministic edge map of red and green, so it carries nothing they lack. That is the paper's central claim. Seed 42; why blue and not green comes after the defenses.

Only one of four defenses moves the attack at all

Defense	Blue / fusion	Full RGB	Clean acc., full RGB
No defense	15/15	15/15	0.8400
L2 clipping	15/15	15/15	0.8533
Coordinate-wise median	15/15	15/15	0.8400
Trimmed mean	15/15	15/15	0.8133
Multi-Krum	15/15	6/15	0.7600

Multi-Krum is the only defense that moved the attack at all, so it is the one carried to the multi-seed stage — even though under blue/fusion it too leaves the backdoor at 15 of 15.

Single seed, seed 42 — which turns out to be the seed where blue/fusion defeats Multi-Krum. Counts are out of the 15 AgentTesla test images; the paper prints them as rates, 1.0000 and 0.4000.

Across three seeds, both strong triggers hit 15 of 15

15/15

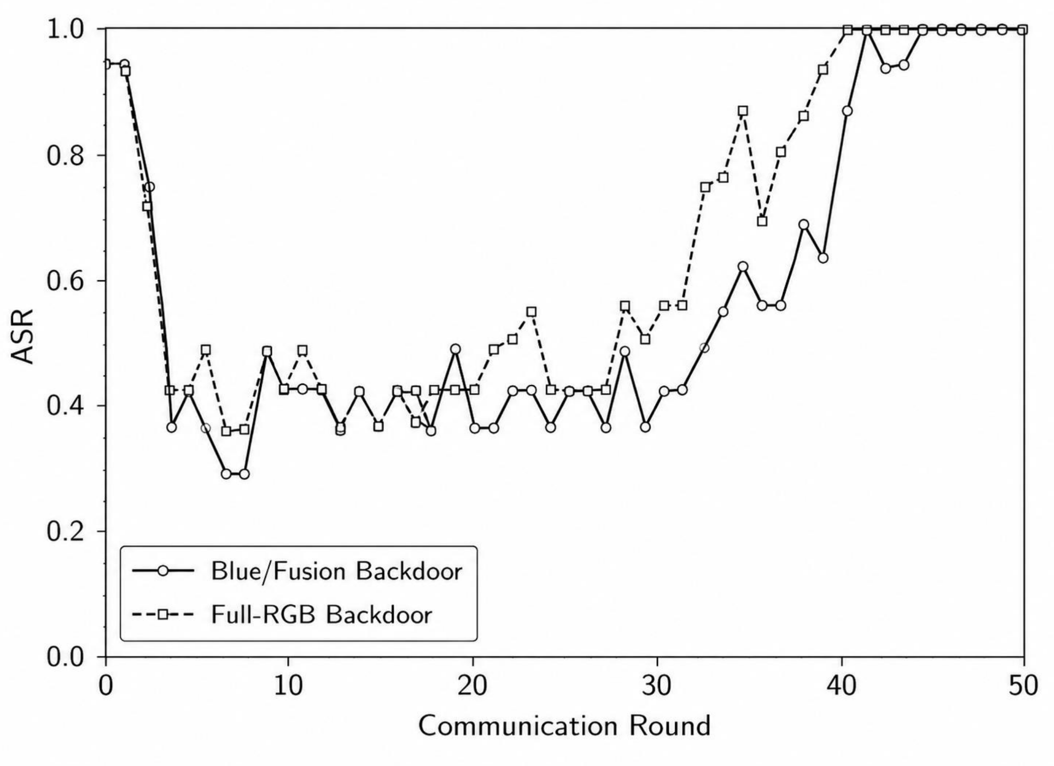
on every seed, for blue/fusion and for full RGB under FedAvg

0.8311 ± 0.0539

clean accuracy under the blue/fusion backdoor, against 0.8267 ± 0.0134 for clean FL

7 of 8

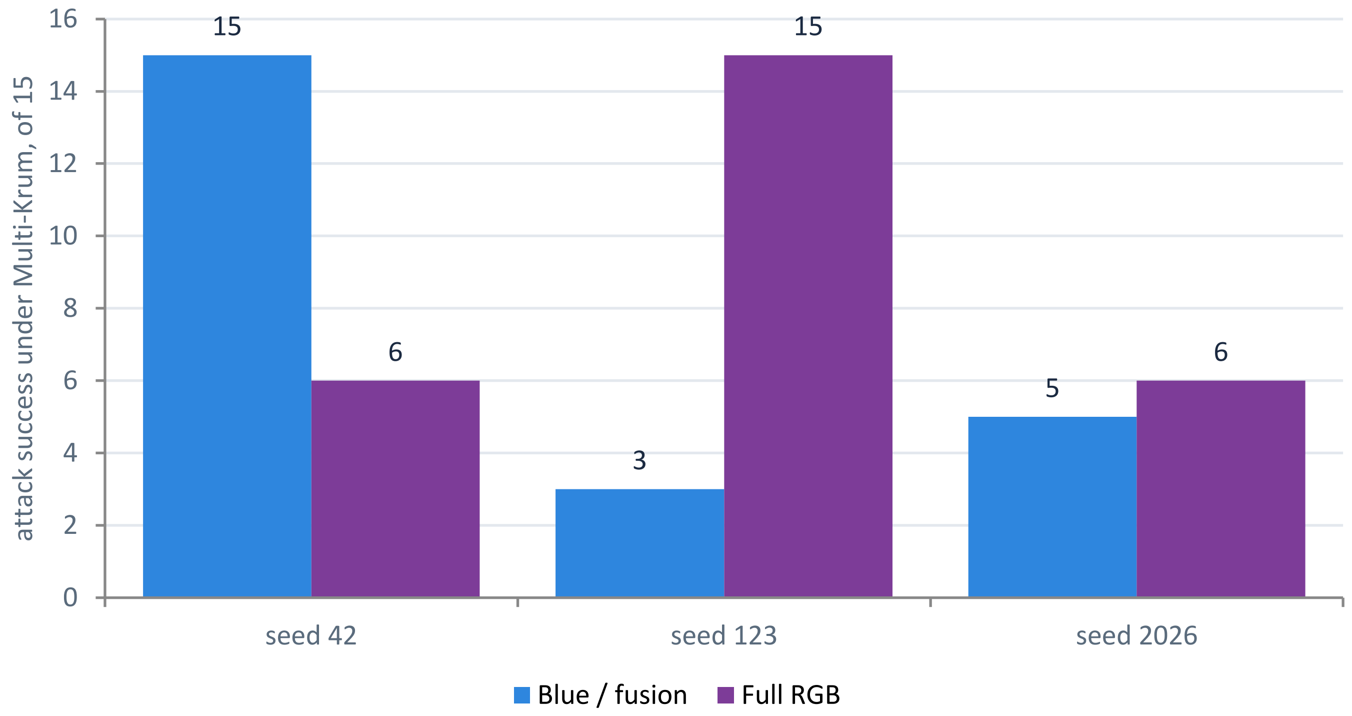
trigger controls give the same target rate with and without the trigger; per seed 4/15, 1/15, 1/15



Attack success over the 50 rounds, seed 42

Clean accuracy stays comparable on average, but its spread is four times the baseline's and on seed 123 it falls to 0.7733. Re-trained under the common budget, the seed-42 baseline gives 0.7867 accuracy and a control rate of 6/15 rather than 4/15.

Multi-Krum does not half-work. It flips.



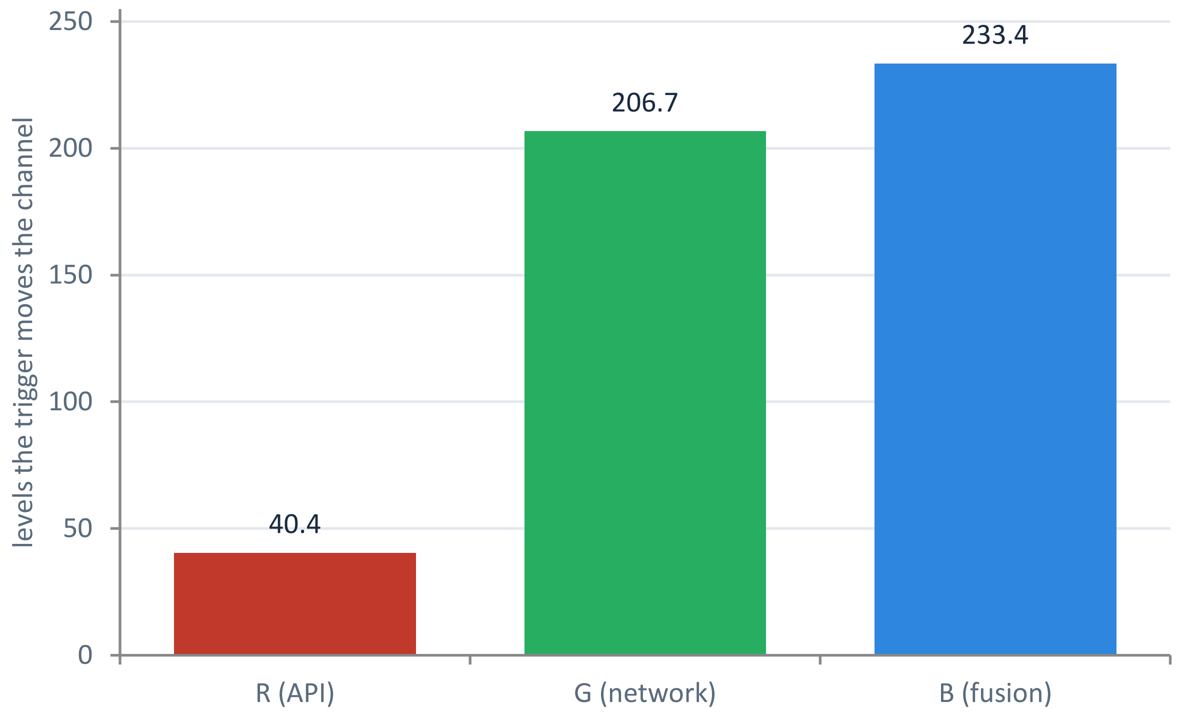
0.5111 ± 0.4286

describes no run we actually observed.

- For each trigger, one seed of three shows no suppression at all: 15 of 15.
- Multi-Krum does cut the attack against FedAvg, $p = 1.5e\text{-}08$ and $9.1e\text{-}07$. It is unreliable as a standalone defense, not ineffective.
- Clean accuracy is nominally lower, but no paired difference is significant at $n = 3$, all $p \geq 0.42$.

The across-seed range is at least 0.5, so the paper reports per-seed counts and never the mean alone. The one concrete utility cost is on seed 42, where full-RGB clean accuracy falls from 0.8400 to 0.7600.

The leading explanation: blue's channel is nearly empty



- 37.7% of red trigger-region pixels are already at 254 or above, where writing a white trigger changes nothing.
- Contrast explains red's failure but not green's, whose contrast is 207 and which still fails.
- Blue is a deterministic edge map, so its effect cannot come from information red and green lack. What is left is that it is almost empty.

Stated as a hypothesis, not a finding. A contrast-matched trigger is the experiment that would settle it.

Contrast is 255 minus the mean intensity inside the bottom-right trigger region, over the 500 clean images. Region means are 214.6 / 48.3 / 21.6; whole-image channel means are 241.7 / 81.5 / 10.2. The measured region is about 13 px per side, 10% of the image.

It flips because selection is close to a coin flip

Run	Malicious client kept	Rate	Final attack success
Blue / fusion, seed 42	25 of 50	50%	**15/15**
Blue / fusion, seed 123	4 of 50	8%	3/15
Blue / fusion, seed 2026	16 of 50	32%	5/15
Full RGB, seed 42	14 of 50	28%	6/15
Full RGB, seed 123	22 of 50	44%	**15/15**
Full RGB, seed 2026	9 of 50	18%	6/15

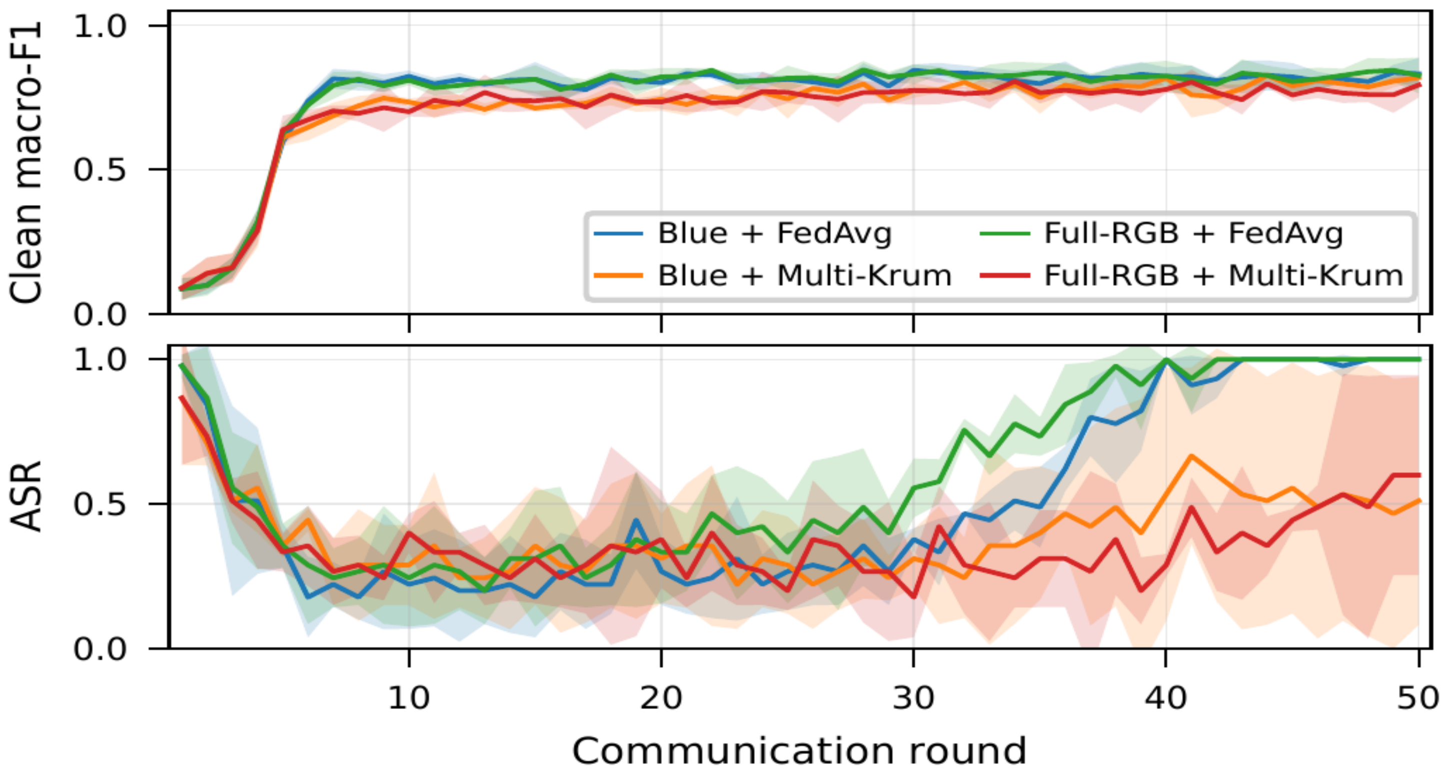
$r = 0.893$, $p = 0.017$

Pearson, across the six runs, $n = 6$

- With $f = 1$ and $|S| = 2$ of five clients, the poisoned update is not an outlier in parameter space.
- Surviving selection is close to a coin flip, and the attacker only has to win often enough.

The rank correlation is weaker and not significant at this size: Spearman rho = 0.794, p = 0.059, n = 6. Retention tracks the outcome; it is not established as the cause.

Under Multi-Krum the attack never settles



- The backdoored models track the clean baseline in macro-F1 throughout training.
- Under FedAvg both triggers climb to 15 of 15 and stay there.
- Under Multi-Krum the curves stay unstable round to round, so there is no stable partial suppression level to rely on.

Per-round test-set curves across the three seeds; shaded areas are the standard deviation across seeds. The first rounds are not meaningful: the global model is still close to initialization and collapses onto one or two classes.

What the evidence supports, and where it stops

ESTABLISHED

- Blue/fusion and full-RGB triggers reach 15 of 15 across three seeds, with clean performance close to the baseline.
- In seven of the eight trigger controls the target rate is identical with and without the trigger, so the effect comes from poisoning.
- Multi-Krum reduces the attack bimodally rather than partially, leaving it fully effective on one of the three seeds for each trigger.

NOT ESTABLISHED

Three seeds

and the red and green results rest on seed 42 alone

One source-target pair

AgentTesla to FormBook only

IID partition only

although the motivation for federation is non-IID data

Emptiness is a hypothesis

consistent with the measurements, not established

A non-IID partition, a second source-target pair and a contrast-matched trigger are the three experiments left to future work. The split files already carry a non-IID client assignment, so that one is available rather than blocked.

What to take away

The channel is the attack surface

A trigger in the fusion channel alone matches one spanning all three. Red and green do nothing measurable.

The effective channel carries no information

Blue is a deterministic edge map of the other two, and the emptiest of the three.

Robust aggregation flips rather than degrades

Multi-Krum leaves the backdoor fully effective on one seed in three, so it is unreliable on its own.

Defenses that inspect updates miss a threat that lives in the representation. In this controlled IID setting, that motivates representation-aware defenses.